

Audit Technique



Élaboré par : Sahbi MOALLA

Auditeur expert en audit de sécurité informatique

Certifié par l'ANSI

Certifié StonGate Firewall Engineer

Certifié StonGate Firewall Architect

Certifié Lead Implementer ISO 27001

Introduction

- La deuxième partie de la mission d'audit est l'audit niveau II ou « Audit Technique ».
- But : essayer de détecter les anomalies et les failles qui peuvent constituer une menace pour l'exploitation des différentes composantes du système d'information.

Introduction

- Les failles qui seront recherchées concernent essentiellement :
 - L'architecture du réseau,
 - Les configurations matérielles utilisées,
 - Les configurations logicielles des différentes composantes du réseau,
 - Le flux circulant sur le réseau,
 - Les équipements d'interconnexion de sites,
 - Et les équipements de sécurité existants.

Introduction

- Les failles qui seront recherchées concernent essentiellement :
 - L'architecture du réseau,
 - Les configurations matérielles utilisées,
 - Les configurations logicielles des différentes composantes du réseau,
 - Le flux circulant sur le réseau,
 - Les équipements d'interconnexion de sites,
 - Et les équipements de sécurité existants.

Déroulement de l'audit technique

- L'audit technique sera réalisé selon une succession de phases respectant une approche méthodique allant de la découverte et la reconnaissance du réseau et systèmes audités jusqu'à la réalisation des scénarios d'attaques experts.

Déroulement de l'audit technique

- Dans cette partie du rapport vous allez présenter :
 - Les différentes phases de l'audit technique,
 - Les résultats obtenus,
 - Les analyses des résultats et les recommandations

Phases de l'audit

- Phase 1 : audit de l'architecture du système et des équipements réseau
 - ▣ Reconnaissance de l'architecture du réseau et du plan d'adressage
 - ▣ Sondages des équipements de communication
 - ▣ Le sondage des applications (A ne pas confondre avec un audit des applications)

- Phase 2 : audit des serveurs et des postes de travail sensibles et les équipements de périmètres
 - ▣ Recherche des vulnérabilités des serveurs
 - ▣ Recherche des vulnérabilités des postes de travail
 - ▣ Sondages des services et des flux

Phases de l'audit

- Phase 3 : Test intrusif

Première phase

Audit de l'architecture et des équipements réseau



Introduction

- ❑ Pour évaluer le niveau de sécurité d'un réseau, il faut d'abord le connaître. La première étape est donc **d'avoir une carte du réseau ciblé pour l'auditer.**
- ❑ Cette étape précède la partie analyse des vulnérabilités des systèmes et elle consiste à auditer l'architecture ainsi ces composantes en premier lieu, par:
 - L'inspection des moyens de contrôle d'accès et de leur stratégie d'administration
 - L'utilisation de multiples traçages du réseau et des passerelles,

Introduction

- Interrogation des serveurs DNS, afin de détecter les stations, repérer les équipements de contrôle d'accès sur les frontières externes du réseau.
- Des outils des sondages réseaux sont recommandés dans cette phase (exp : GFI , NetworkView)
- L'inspection du réseau est un point de départ, lors duquel la topologie, ainsi que les hôtes et les équipements réseau seront identifiés.

A- La reconnaissance du réseau

- 1) **Elaboration du schéma du réseau existant**

Le schéma élaboré doit fournir une idée claire sur :

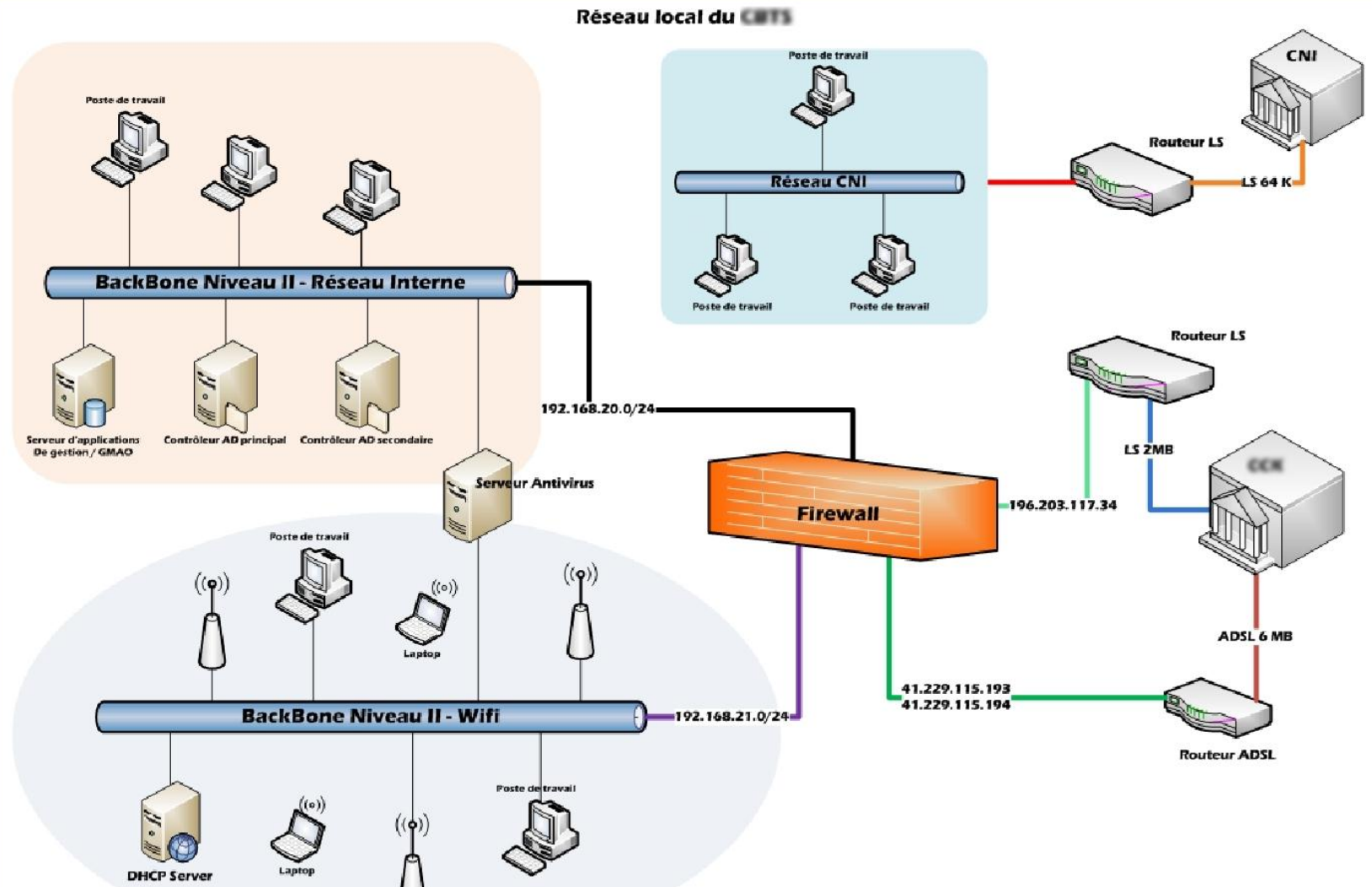
- La réparation géographique des équipements (NB: possibilité d'élaborer un schéma global, et des schémas détaillé pour chaque site)
- L'emplacement des équipements de communication
- La segmentation du réseaux (dmz,vlan,,,,)
- Les équipements de sécurité (firewall, IDS, ,,,)
- Le rôles des serveurs (proxy, dhcp, dns, messagerie, antiviral.....)
- Les postes clients (fixe, portable, smarphone,,,,)

A- La reconnaissance du réseau

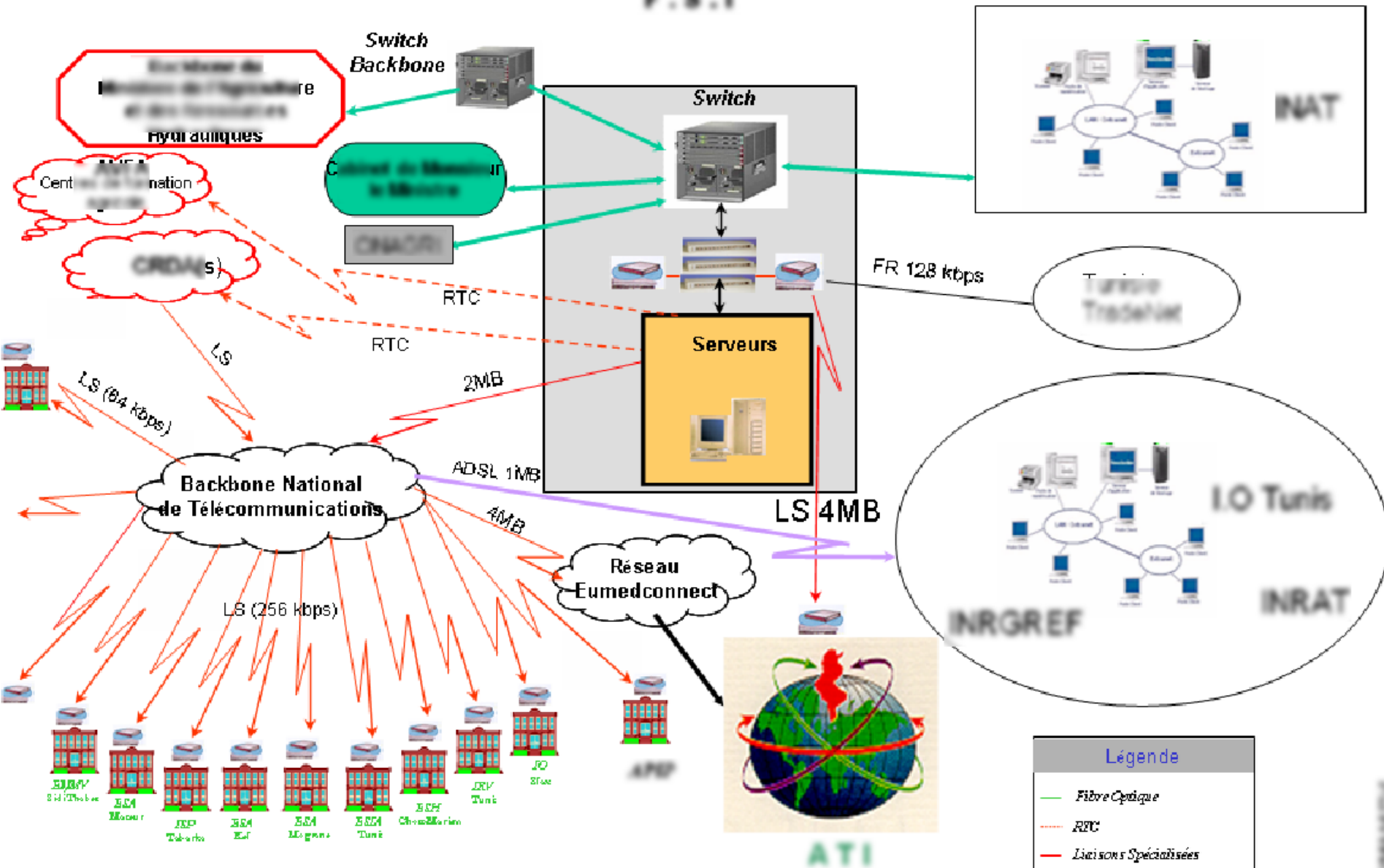
- Les équipements de communication sans-fils
- Les adresses ip des équipements (serveur, switch, pont d'accès, firwal, ,,,,))
- Les réseaux externes : LS , ADSL, FR, WIMAX,,,)
- Un schéma complémentaire est souhaitable pour schématiser le raccordement des armoires réseaux, fibre optiques, réseaux haut débit

→ Il faut s'appuyer sur des outils de schématisation des réseaux informatiques tel que VISIO

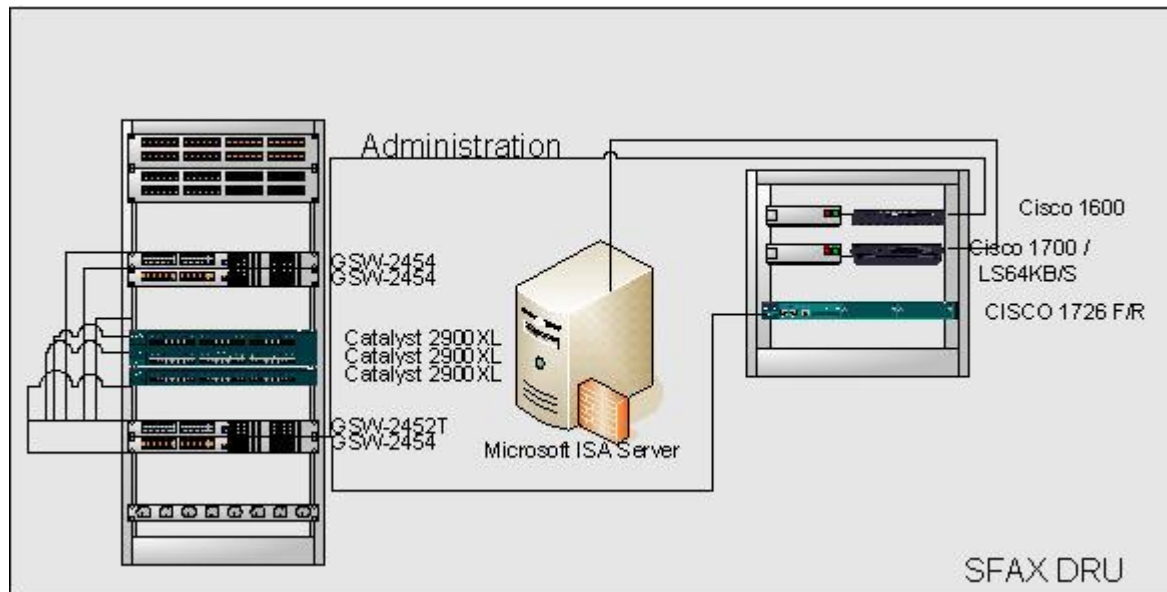
A- La reconnaissance du réseau



Exemple : Schéma global

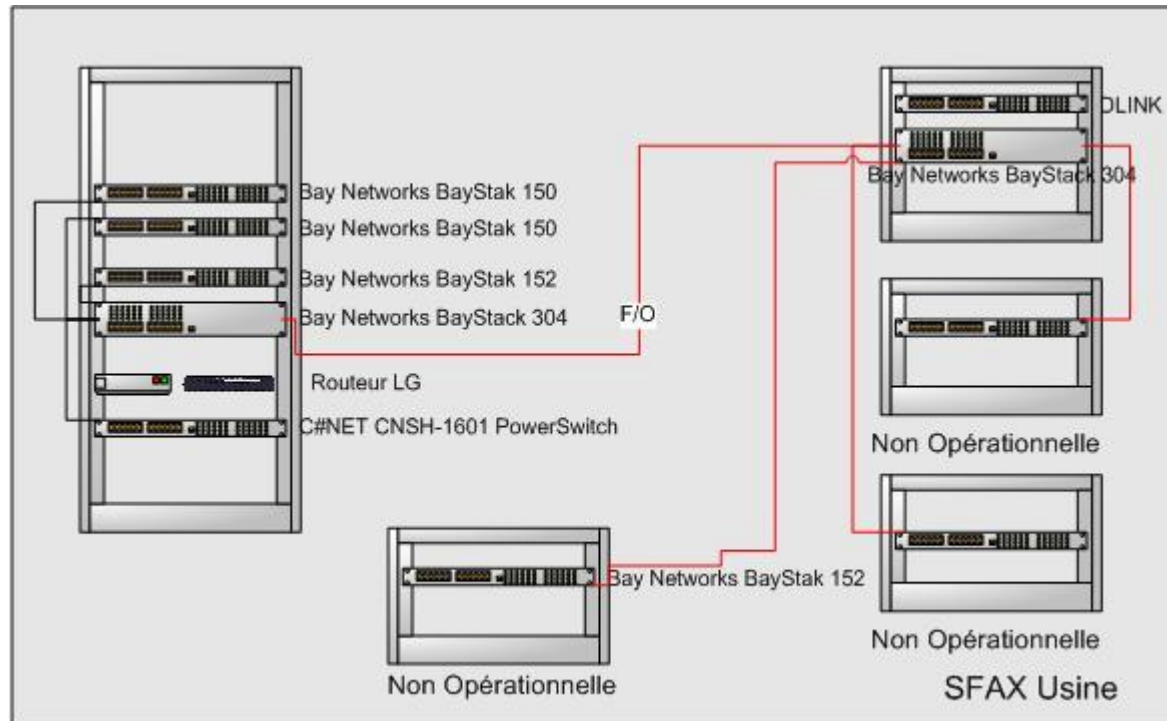


A- La reconnaissance du réseau



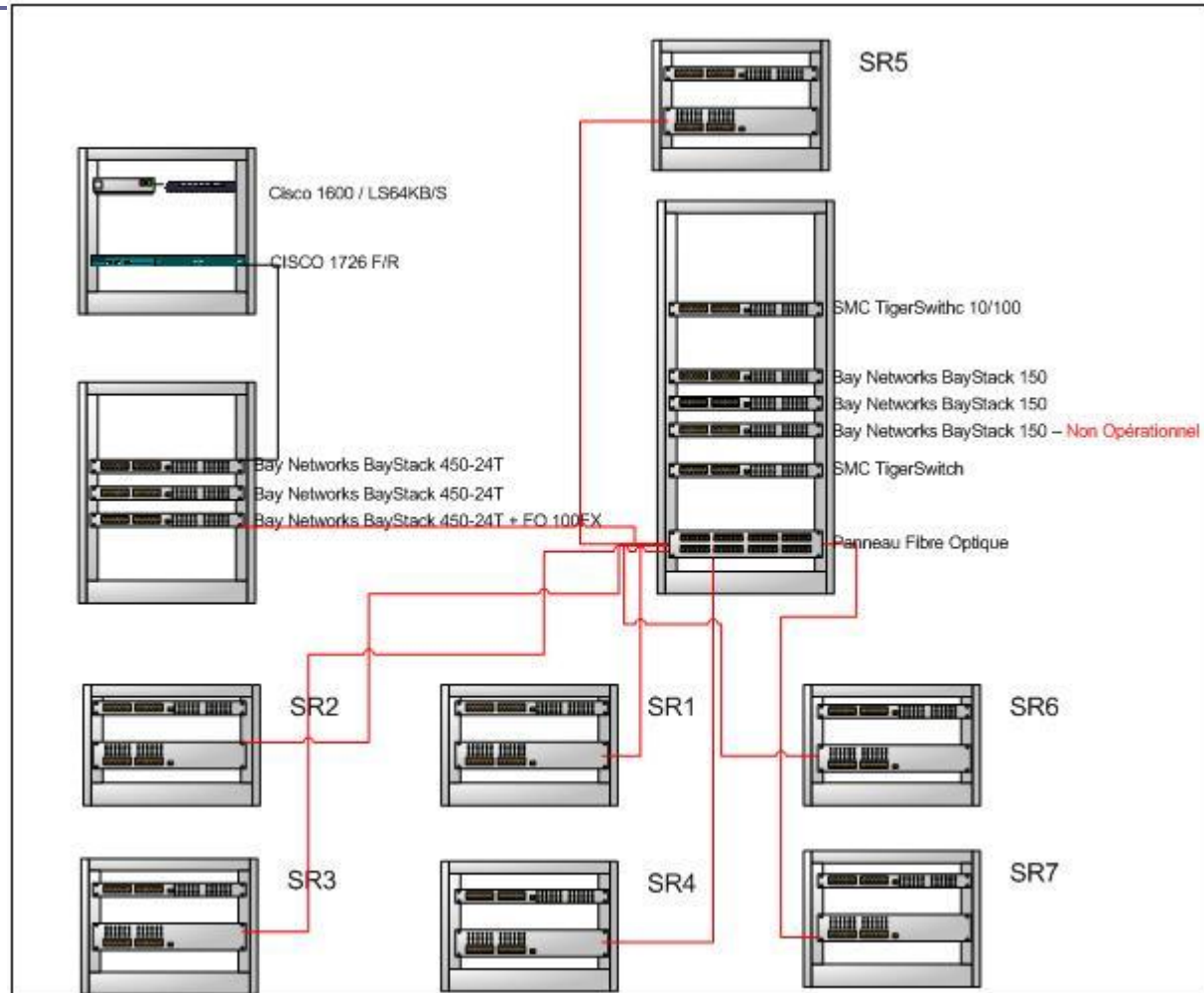
Exemple : Schéma du raccordement des armoires réseaux

A- La reconnaissance du réseau



Exemple : Schéma du raccordement des armoires réseaux

A- La reconnaissance du réseau



A- La reconnaissance du réseau

- Dans les interprétations et les constats , il faut analyser
 - la topologie du réseaux,
 - Une présentation d'un inventaire des équipements clés
 - l'emplacement des équipement de communications,
 - la fiabilités des connexion haut débit,
 - La fiabilité des support de transmissions....

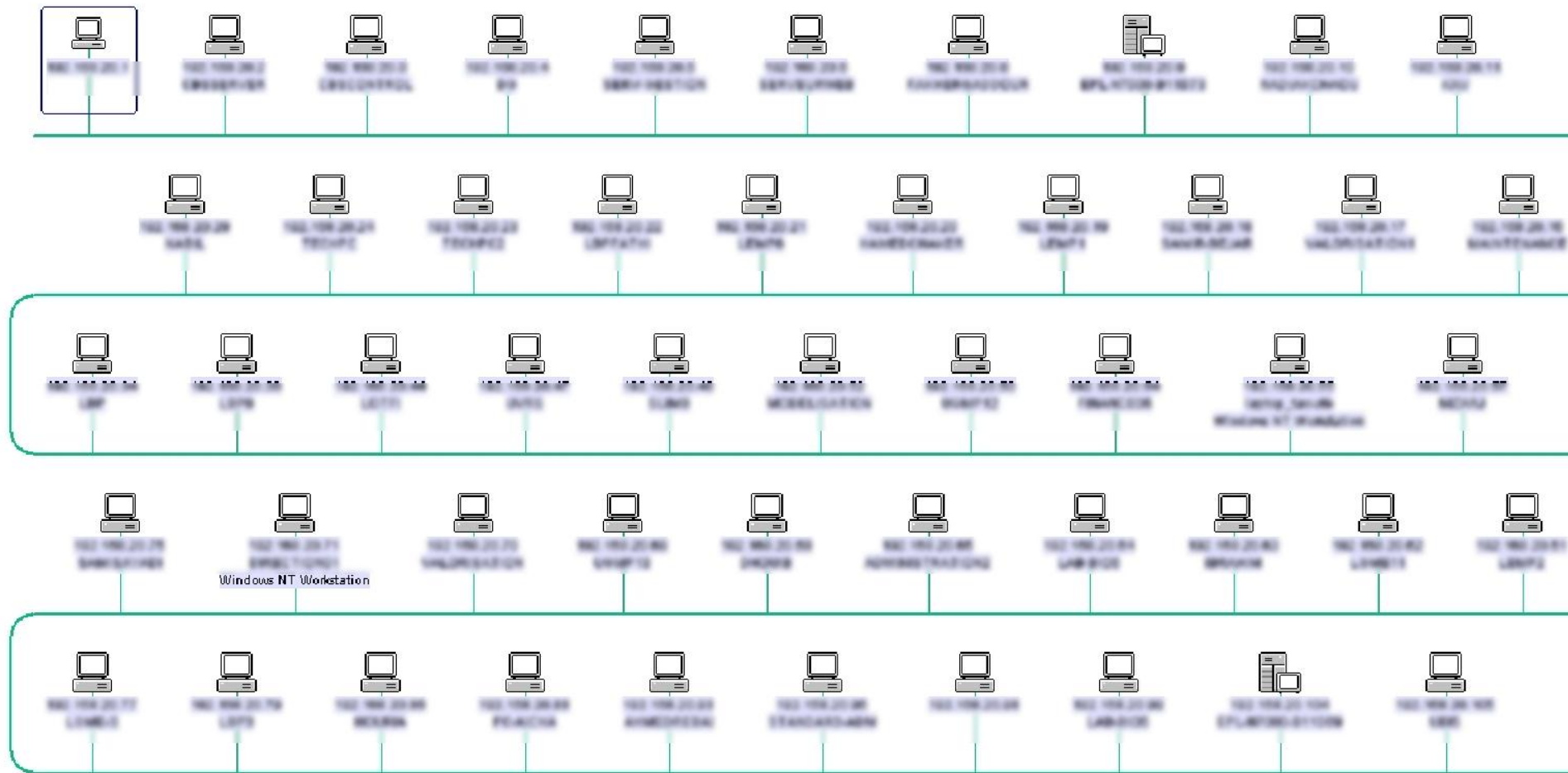
A- La reconnaissance du réseau

2) **La reconnaissance du plan d'adresse**

Le schéma élaboré doit fournir une idée claire sur :

- Les pools d'adresse ip utilisée
- Eventuellement et les adresse fixe et routables
- Les passerelles
- Des outils tels que networkviews est utiles dans cette étape

A- La reconnaissance du réseau



A- La reconnaissance du réseau

- Dans les interprétations et les constats , il faut analyser
 - la conformité des adresse avec la RFC 1918 (adressage privé).
 - Classe d'adressage ip
 - La méthode d'affectation des adresses ip
 - Segmentation du réseau ?
 - La séparation des réseaux externe et interne,
 - ...

B- Sondage des systèmes et des équipements

1- Sondage des systèmes

- Le sondage des systèmes consiste à identifier les systèmes d'exploitation des différents équipements du réseau, les ressources partagées ainsi que les droits d'accès qui y sont appliqués et enfin le niveau de mises à jour et des patches appliqués.
- Les outils utilisés durant cette étape sont : NMAP, Netcat, LanGuard Network Security Scanner et Retina.
- Exemple : Un scan du réseau avec l'outil LNSS nous a donné le résultat suivant :

Audit de l'architecture du système et des équipements réseau

1- Sondage des systèmes



Audit de l'architecture du système et des équipements réseau

2- Sondage des ports, du flux et des services

A- *Sondage des ports*

- Dans cette étape de l'audit technique, les outils NESSUS / GFI seront utilisé pour détecter les ports ouverts sur les équipements actifs du réseau local (serveurs, postes de travail et routeurs...)
- Les scans effectués sur :
 - ▣ Les serveurs & les postes de travail
 - ▣ Les switches & les équipements de sécurité

Audit de l'architecture du système et des équipements réseau

2- Sondage des ports, du flux et des services

A- Sondage des ports

Les résultats :

Échantillon Serveurs:

Ressource	Ports Ouverts
192.168.20.2	Port brvread (1054/tcp) Port kerberos (88/tcp) Port fpp-fns (1066/tcp) Port ntp (123/udp) Port msft-gc-ssl (3269/tcp) Port daytime (13/tcp) Port qt-serveradmin (1220/tcp) Port netbios-ssn (139/tcp) Port discard (9/tcp) Port domain (53/tcp) Port irdmi (8000/tcp) Port msft-gc (3268/tcp) Port http-rpc-epmap (593/tcp) Port chargen (19/tcp) Port echo (7/udp) Port http (80/tcp) Port echo (7/tcp) Port tabula (1437/tcp) Port kpasswd (464/tcp) Port unknown (1044/tcp) Port printer (515/tcp)

Audit de l'architecture du système et des équipements réseau

2- Sondage des ports, du flux et des services

B- Sondage du flux et des services

un sondage du flux qui circule sur le réseau par le biais du sniffer
« **WireShark** ».

Protocol	% Packets	Packets	Bytes	Mbit/s	End Packets	End Bytes	End Mbit/s
Frame	100,00%	30337	6398190	0,016	0	0	0,000
Ethernet	100,00%	30337	6398190	0,016	0	0	0,000
Internet Protocol	59,02%	17904	5350224	0,013	0	0	0,000
User Datagram Protocol	28,08%	8518	1280113	0,003	0	0	0,000
NetBIOS Name Service	18,63%	5653	528139	0,001	5653	528139	0,001
Hypertext Transfer Protocol	2,36%	716	255234	0,001	716	255234	0,001
NetBIOS Datagram Service	3,93%	1193	286124	0,001	0	0	0,000
Domain Name Service	1,29%	390	67544	0,000	390	67544	0,000
Bootstrap Protocol	0,79%	241	95222	0,000	241	95222	0,000
Data	1,06%	323	47718	0,000	323	47718	0,000
Kerberized Internet Negotiation of Key	0,01%	2	132	0,000	0	0	0,000
Transmission Control Protocol	27,77%	8424	4011319	0,010	7087	3206257	0,008
Hypertext Transfer Protocol	2,60%	789	500065	0,001	613	389024	0,001
Secure Socket Layer	0,50%	151	91699	0,000	151	91699	0,000
NetBIOS Session Service	0,33%	101	16414	0,000	10	856	0,000
DCE RPC	0,00%	1	275	0,000	1	275	0,000
Telnet	0,03%	8	936	0,000	8	936	0,000
Internet Group Management Protocol	3,12%	947	56874	0,000	947	56874	0,000
Internet Control Message Protocol	0,05%	15	1918	0,000	15	1918	0,000
Internet Protocol Version 6	4,33%	1314	339193	0,001	0	0	0,000
Address Resolution Protocol	26,33%	7988	478742	0,001	7988	478742	0,001
Logical-Link Control	8,21%	2490	190067	0,000	0	0	0,000
HP Extended Local-Link Control	0,18%	56	5936	0,000	0	0	0,000
Spanning Tree Protocol	5,32%	1613	96780	0,000	1613	96780	0,000
Internetwork Packet eXchange	2,14%	648	54864	0,000	0	0	0,000
Data	0,40%	120	14732	0,000	120	14732	0,000
Cisco Discovery Protocol	0,17%	53	17755	0,000	53	17755	0,000
Internetwork Packet eXchange	2,11%	641	39964	0,000	0	0	0,000
Service Advertisement Protocol	0,87%	265	15900	0,000	265	15900	0,000
IPX Routing Information Protocol	1,24%	376	24064	0,000	376	24064	0,000

Répartition de l'utilisation de protocoles

Wireshark: 43 Expert Infos				
Errors: 2 Warnings: 41 Notes: 467 Chats: 3627			Severity filter: Error+Warn	
No.	Sever.	Group	Protocol	Summary
17840	Error	Malformed	KINK	Malformed Packet (Exception occurred)
17842	Error	Malformed	KINK	Malformed Packet (Exception occurred)
1224	Warn	Sequence	TCP	Previous segment lost (common at capture start)
3049	Warn	Sequence	TCP	Previous segment lost (common at capture start)
3199	Warn	Sequence	TCP	Previous segment lost (common at capture start)
3206	Warn	Sequence	TCP	Previous segment lost (common at capture start)
3220	Warn	Sequence	TCP	Previous segment lost (common at capture start)
3222	Warn	Sequence	TCP	Previous segment lost (common at capture start)
3960	Warn	Sequence	TCP	Previous segment lost (common at capture start)
4758	Warn	Sequence	TCP	Previous segment lost (common at capture start)
4773	Warn	Sequence	TCP	Previous segment lost (common at capture start)
4795	Warn	Sequence	TCP	Previous segment lost (common at capture start)
4803	Warn	Sequence	TCP	Previous segment lost (common at capture start)
4805	Warn	Sequence	TCP	Previous segment lost (common at capture start)
4808	Warn	Sequence	TCP	Previous segment lost (common at capture start)
4826	Warn	Sequence	TCP	Previous segment lost (common at capture start)
4831	Warn	Sequence	TCP	Previous segment lost (common at capture start)
4837	Warn	Sequence	TCP	Previous segment lost (common at capture start)
4899	Warn	Sequence	TCP	Fast retransmission (suspected)
4932	Warn	Sequence	TCP	Fast retransmission (suspected)
4942	Warn	Sequence	TCP	Fast retransmission (suspected)
5848	Warn	Malformed	OCSP	BER Error Dissector for OID not implemented
6038	Warn	Malformed	OCSP	BER Error Dissector for OID not implemented
6478	Warn	Sequence	TCP	Previous segment lost (common at capture start)
7739	Warn	Sequence	TCP	Previous segment lost (common at capture start)
7743	Warn	Sequence	TCP	Previous segment lost (common at capture start)
7756	Warn	Sequence	TCP	Previous segment lost (common at capture start)
7782	Warn	Sequence	TCP	Previous segment lost (common at capture start)
7788	Warn	Sequence	TCP	Previous segment lost (common at capture start)
7824	Warn	Sequence	TCP	Fast retransmission (suspected)
7851	Warn	Sequence	TCP	Fast retransmission (suspected)
7869	Warn	Sequence	TCP	Fast retransmission (suspected)
7965	Warn	Sequence	TCP	Previous segment lost (common at capture start)
8013	Warn	Sequence	TCP	Previous segment lost (common at capture start)
8040	Warn	Sequence	TCP	Fast retransmission (suspected)
8185	Warn	Sequence	TCP	Previous segment lost (common at capture start)
8266	Warn	Sequence	TCP	Fast retransmission (suspected)
12043	Warn	Sequence	TCP	Previous segment lost (common at capture start)
12047	Warn	Sequence	TCP	Previous segment lost (common at capture start)
13462	Warn	Malformed	OCSP	BER Error Dissector for OID not implemented
14617	Warn	Sequence	TCP	Previous segment lost (common at capture start)
19359	Warn	Sequence	TCP	Previous segment lost (common at capture start)
19431	Warn	Sequence	TCP	Previous segment lost (common at capture start)

Close

Analyse du trafic

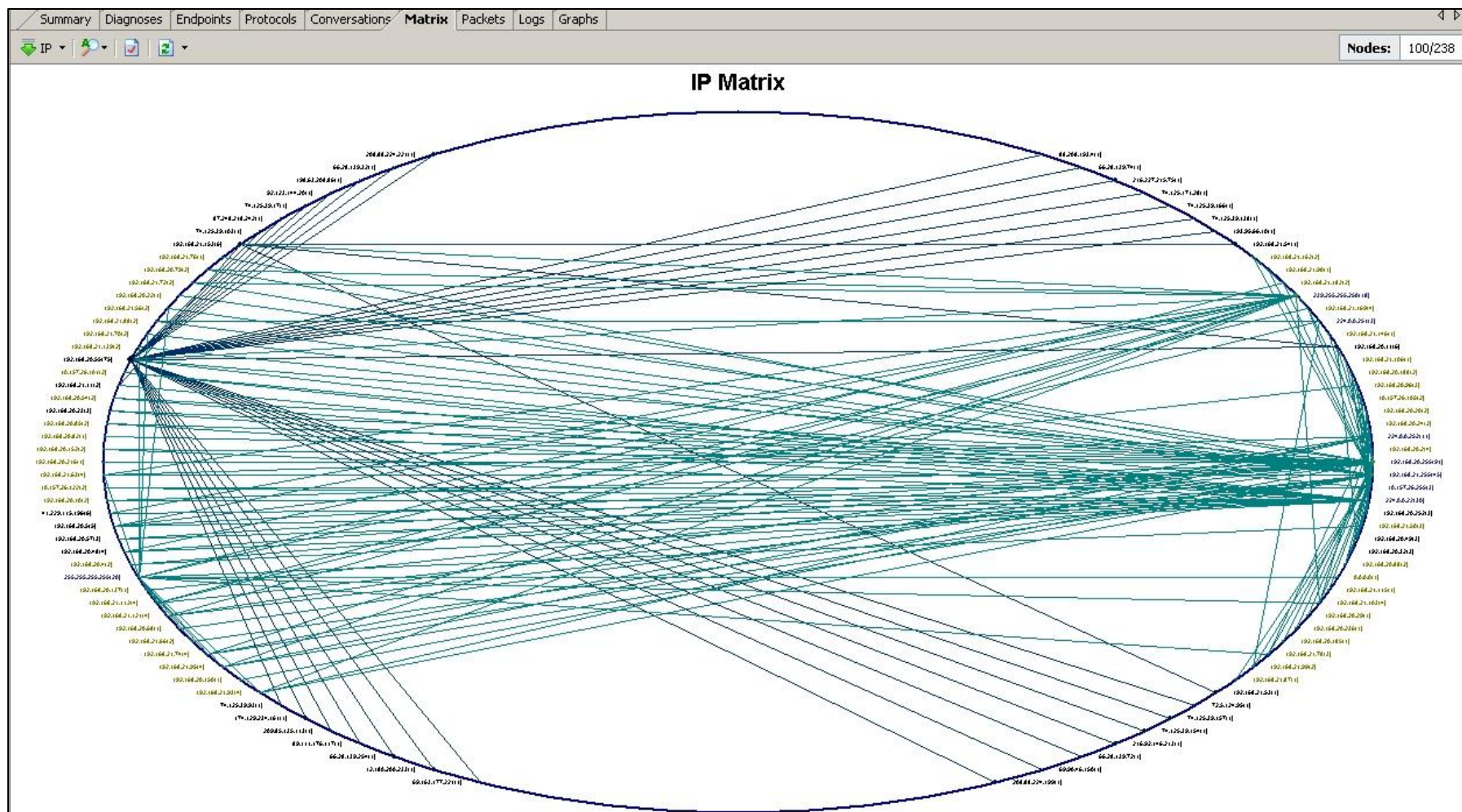
Summary							Diagnoses	Endpoints	Protocols	Conversations	Matrix	Packets	Logs	Graphs
   														
Statistics							Current							
[-] Capture														
Start Date							2009-10-18							
Start Time							20:34:06							
Duration							00:00:38							
[-] Traffic							Bytes	Packets	Utilization	Bits Per Second	pps			
Total Traffic							6.218 MB	30,337	0.002%	1.536 Kbps	3			
Broadcast Traffic Sent							1.477 MB	16,361	0.001%	1.024 Kbps	2			
Multicast Traffic Sent							361.115 KB	2,044	0.000%	0 bps	0			
[-] Packet Size Distribution							Bytes	Packets	Utilization	Bits Per Second	pps			
<=64							900.195 KB	14,644	0.002%	1.536 Kbps	3			
65-127							775.814 KB	8,757	0.000%	0 bps	0			
128-255							439.169 KB	2,176	0.000%	0 bps	0			
256-511							461.291 KB	1,181	0.000%	0 bps	0			
512-1023							716.169 KB	1,167	0.000%	0 bps	0			
1024-1517							2.996 MB	2,408	0.000%	0 bps	0			
>=1518							5.930 KB	4	0.000%	0 bps	0			
[-] TCP Packets							Bytes	Packets	Utilization	Bits Per Second	pps			
TCP SYN Packets							50.184 KB	752	0.000%	0 bps	0			
TCP FIN Packets							79.447 KB	697	0.000%	0 bps	0			
TCP Reset Packets							4.648 KB	80	0.000%	0 bps	0			
[-] TCP Connections							Count							
TCP Connection Initiated							429							
TCP Connection Established							419							

Résumé du trafic

Protocol Statistics

Name	Percentage	Bytes	Packets
Ethernet II	96.606%	6,007 MB	27,527
IP	83.163%	5,171 MB	17,904
TCP	62.045%	3,858 MB	8,424
HTTP	56.479%	3,512 MB	7,605
HTTPS	5.231%	333.064 KB	650
NetBIOS	0.192%	12.250 KB	92
Session Service	0.192%	12.250 KB	92
CIFS	0.107%	6.781 KB	51
TELNET	0.028%	1.805 KB	22
Other	0.007%	481 B	4
UDP	20.158%	1,253 MB	8,518
NetBIOS	12.763%	812.604 KB	6,749
Name Service	8.301%	528.526 KB	5,556
Datagram Service	4.462%	284.078 KB	1,193
Other	4.713%	300.047 KB	1,041
BOOTP	1.475%	93.932 KB	241
DHCP	1.475%	93.932 KB	241
DNS	1.049%	66.767 KB	386
Response	0.814%	51.825 KB	203
Query	0.235%	14.941 KB	183
RTCP	0.158%	10.034 KB	101
IGMP	0.930%	59.240 KB	947
ICMP	0.030%	1.932 KB	15
Dest Unreach	0.023%	1.475 KB	9
Echo Reply	0.004%	234 B	3
Echo Req	0.004%	234 B	3
ARP	7.833%	498.725 KB	7,988
Request	7.811%	497.289 KB	7,958
Response	0.023%	1.436 KB	30
IPv6	5.283%	336.376 KB	1,314
UDP	4.812%	306.360 KB	976
Other	4.812%	306.360 KB	976

Résumé sur les protocoles



Matrice de répartition des communications

Audit de l'architecture du système et des équipements réseau

3) Le sondage des applications

(A ne pas confondre avec un audit des applications)

- Enumérer les applications les plus importantes, leurs version
- Analyser les contrôles d'accées a l'application, la méthode d'authentification
- Le contrat de support et maintenance
-

Deuxième phase

Audit des serveurs et des postes
de travail sensibles



Détection des failles de sécurité

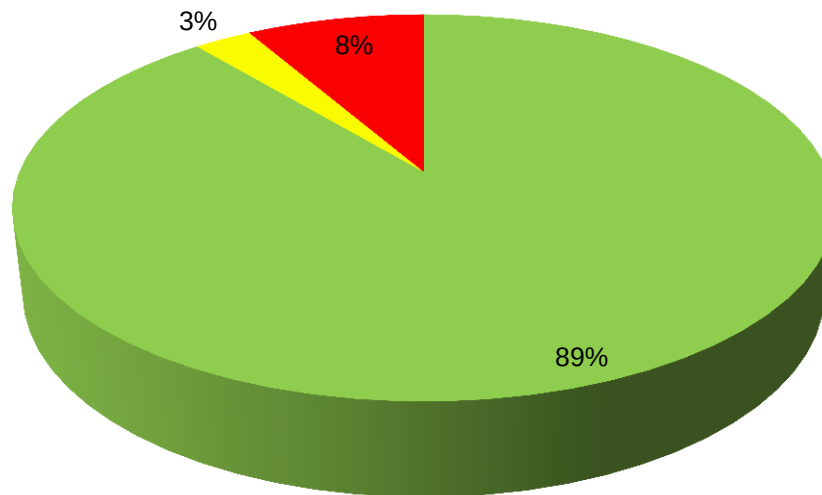
- Cette phase sera scindée en deux étapes:
 - ▣ Une première étape consiste à un balayage global pour la détection des failles présentes sur tous les équipements qui constituent le système d'information
 - ▣ La deuxième étape consiste à détecter et à identifier les machines les plus vulnérables et réaliser par la suite un scan ciblé et approfondi de ces équipements.
- Les outils utilisés durant cette phase sont NMAP, NESSUS, LanGuard et Retina.

Détection des failles de sécurité

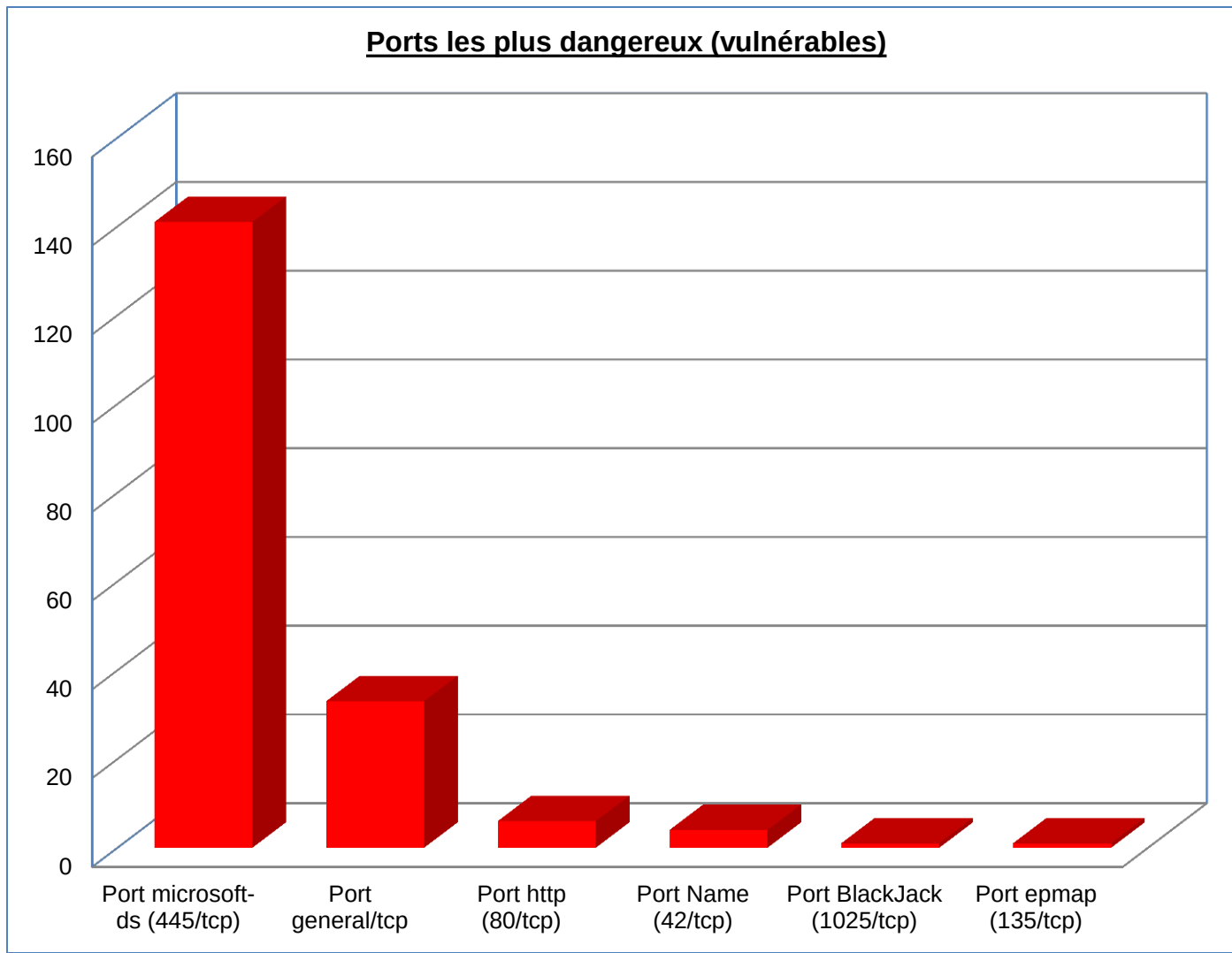
1- Première étape : Audit global du réseau

Répartition Globale des Vulnérabilités

■ Low vulnerabilities ■ Medium vulnerabilities ■ High vulnerabilities



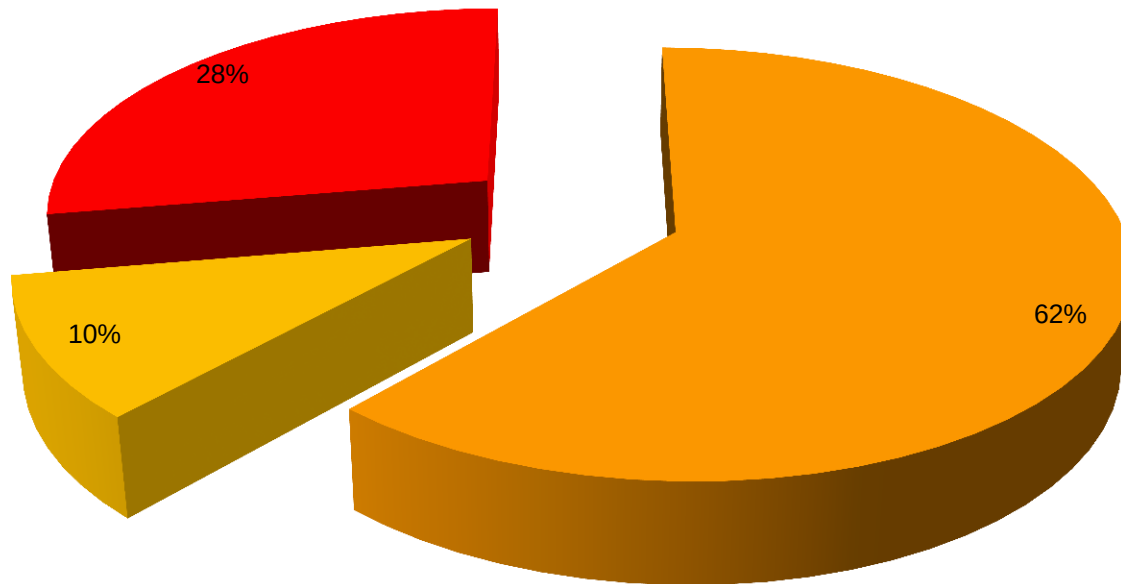
Détection des failles de sécurité



Détection des failles de sécurité

La machine la plus vulnérable

■ Low vulnerabilities ■ Medium vulnerabilities ■ High vulnerabilities



Détection des failles de sécurité

2- Seconde étape : Audit détaillée par ressource.

Exemple : Audit du Serveur contrôleur principal de domaine

Après une série de vérifications, de mesures et de scans de vulnérabilités par différents outils, nous avons obtenus les résultats suivants :

Le serveur comporte:

- 41 ports ouverts
- 76 vulnérabilités faibles
- 8 vulnérabilités moyennes sur les services et les ports suivants :

✓ **Port msft-gc-ssl (3269/tcp)**

SSL Version 2 (v2) Protocol Detection

Synopsis:

The remote service encrypts traffic using a protocol with known weaknesses

Description:

The remote service accepts connections encrypted using SSL 2.0, which reportedly suffers from several cryptographic flaws and has been deprecated for several years. An attacker may be able to exploit these issues to conduct man-in-the-middle attacks or decrypt communications between the affected service and clients.

See also:

<http://www.schneier.com/paper-ssl.pdf>

Solution:

Consult the application's documentation to disable SSL 2.0 and use SSL 3.0 or TLS 1.0 instead.

Risk factor:

Medium / CVSS Base Score: 5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

Nessus ID: 20007

SSL Weak Cipher Suites Supported

Synopsis:

The remote service supports the use of weak SSL ciphers.

Description:

The remote host supports the use of SSL ciphers that offer either weak encryption or no encryption at all.

See also:

<http://www.openssl.org/docs/apps/ciphers.html>

Solution:

Reconfigure the affected application if possible to avoid use of weak ciphers.

Risk factor:

Medium / CVSS Base Score: 5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

Détection des failles de sécurité

2- Seconde étape : Audit détaillée par ressource.

Audit de la politique de sécurité du serveur :

Conformité par rapport à un référentiel :

- La stabilité et la fiabilité des systèmes d'exploitation dépendent principalement de la politique de sécurité mise en place sur le serveur. .

Détection des failles de sécurité

2- Seconde étape : Audit détaillée par ressource.

Audit de la politique de sécurité du serveur : **Conformité par rapport à un référentiel :**

- ❑ Cette analyse se basera sur un référentiel de sécurité éditée par : ***The Center For Internet Security « CIS »***
www.cisecurity.org
- ❑ ***The Center for Internet Security (CIS)*** est une entreprise à but non lucratif dont la mission est d'aider les organisations à réduire les risques et les perturbations dans leurs business causées par l'insuffisance des contrôles de sécurité.
- ❑ Voir annexe

Détection des failles de sécurité

2- Seconde étape : Audit détaillée par ressource.

Audit des services d'annuaire « Active Directory »

Workstations :

Last Logon : 12 Oct 2009, 6:36:20

Password age : 994 days, 6 hours, 37 minutes, 58 seconds

* Logons : 12158

Bad Passwords Count : 0

1

2. L'existence d'un compte d'utilisateur ayant les pouvoirs d'administrateur

Privilege : Administrator (*)

CONCLUSIONS

UserCommer

ScriptPath :

Workstations :

WORKSHEETS : 11, 12, 13, 14, 15, 16, 17, 18, 19, 20, 21, 22, 23, 24, 25, 26, 27, 28, 29, 30, 31, 32, 33, 34, 35, 36, 37, 38, 39, 40, 41, 42, 43, 44, 45, 46, 47, 48, 49, 50, 51, 52, 53, 54, 55, 56, 57, 58, 59, 60, 61, 62, 63, 64, 65, 66, 67, 68, 69, 70, 71, 72, 73, 74, 75, 76, 77, 78, 79, 80, 81, 82, 83, 84, 85, 86, 87, 88, 89, 90, 91, 92, 93, 94, 95, 96, 97, 98, 99, 100, 101, 102, 103, 104, 105, 106, 107, 108, 109, 110, 111, 112, 113, 114, 115, 116, 117, 118, 119, 120, 121, 122, 123, 124, 125, 126, 127, 128, 129, 130, 131, 132, 133, 134, 135, 136, 137, 138, 139, 140, 141, 142, 143, 144, 145, 146, 147, 148, 149, 150, 151, 152, 153, 154, 155, 156, 157, 158, 159, 160, 161, 162, 163, 164, 165, 166, 167, 168, 169, 170, 171, 172, 173, 174, 175, 176, 177, 178, 179, 180, 181, 182, 183, 184, 185, 186, 187, 188, 189, 190, 191, 192, 193, 194, 195, 196, 197, 198, 199, 200, 201, 202, 203, 204, 205, 206, 207, 208, 209, 210, 211, 212, 213, 214, 215, 216, 217, 218, 219, 220, 221, 222, 223, 224, 225, 226, 227, 228, 229, 230, 231, 232, 233, 234, 235, 236, 237, 238, 239, 240, 241, 242, 243, 244, 245, 246, 247, 248, 249, 250, 251, 252, 253, 254, 255, 256, 257, 258, 259, 260, 261, 262, 263, 264, 265, 266, 267, 268, 269, 270, 271, 272, 273, 274, 275, 276, 277, 278, 279, 280, 281, 282, 283, 284, 285, 286, 287, 288, 289, 290, 291, 292, 293, 294, 295, 296, 297, 298, 299, 300, 301, 302, 303, 304, 305, 306, 307, 308, 309, 310, 311, 312, 313, 314, 315, 316, 317, 318, 319, 320, 321, 322, 323, 324, 325, 326, 327, 328, 329, 330, 331, 332, 333, 334, 335, 336, 337, 338, 339, 340, 341, 342, 343, 344, 345, 346, 347, 348, 349, 350, 351, 352, 353, 354, 355, 356, 357, 358, 359, 360, 361, 362, 363, 364, 365, 366, 367, 368, 369, 370, 371, 372, 373, 374, 375, 376, 377, 378, 379, 380, 381, 382, 383, 384, 385, 386, 387, 388, 389, 390, 391, 392, 393, 394, 395, 396, 397, 398, 399, 400, 401, 402, 403, 404, 405, 406, 407, 408, 409, 410, 411, 412, 413, 414, 415, 416, 417, 418, 419, 420, 421, 422, 423, 424, 425, 426, 427, 428, 429, 430, 431, 432, 433, 434, 435, 436, 437, 438, 439, 440, 441, 442, 443, 444, 445, 446, 447, 448, 449, 450, 451, 452, 453, 454, 455, 456, 457, 458, 459, 460, 461, 462, 463, 464, 465, 466, 467, 468, 469, 470, 471, 472, 473, 474, 475, 476, 477, 478, 479, 480, 481, 482, 483, 484, 485, 486, 487, 488, 489, 490, 491, 492, 493, 494, 495, 496, 497, 498, 499, 500, 501, 502, 503, 504, 505, 506, 507, 508, 509, 510, 511, 512, 513, 514, 515, 516, 517, 518, 519, 520, 521, 522, 523, 524, 525, 526, 527, 528, 529, 530, 531, 532, 533, 534, 535, 536, 537, 538, 539, 540, 541, 542, 543, 544, 545, 546, 547, 548, 549, 550, 551, 552, 553, 554, 555, 556, 557, 558, 559, 560, 561, 562, 563, 564, 565, 566, 567, 568, 569, 570, 571, 572, 573, 574, 575, 576, 577, 578, 579, 580, 581, 582, 583, 584, 585, 586, 587, 588, 589, 590, 591, 592, 593, 594, 595, 596, 597, 598, 599, 600, 601, 602, 603, 604, 605, 606, 607, 608, 609, 610, 611, 612, 613, 614, 615, 616, 617, 618, 619, 620, 621, 622, 623, 624, 625, 626, 627, 628, 629, 630, 631, 632, 633, 634, 635, 636, 637, 638, 639, 640, 641, 642, 643, 644, 645, 646, 647, 648, 649, 650, 651, 652, 653, 654, 655, 656, 657, 658, 659, 660, 661, 662, 663, 664, 665, 666, 667, 668, 669, 670, 671, 672, 673, 674, 675, 676, 677, 678, 679, 680, 681, 682, 683, 684, 685, 686, 687, 688, 689, 690, 691, 692, 693, 694, 695, 696, 697, 698, 699, 700, 701, 702, 703, 704, 705, 706, 707, 708, 709, 710, 711, 712, 713, 714, 715, 716, 717, 718, 719, 720, 721, 722, 723, 724, 725, 726, 727, 728, 729, 730, 731, 732, 733, 734, 735, 736, 737, 738, 739, 740, 741, 742, 743, 744, 745, 746, 747, 748, 749, 750, 751, 752, 753, 754, 755, 756, 757, 758, 759, 760, 761, 762, 763, 764, 765, 766, 767, 768, 769, 770, 771, 772, 773, 774, 775, 776, 777, 778, 779, 780, 781, 782, 783, 784, 785, 786, 787, 788, 789, 790, 791, 792, 793, 794, 795, 796, 797, 798, 799, 800, 801, 802, 803, 804, 805, 806, 807, 808, 809, 810, 811, 812, 813, 814, 815, 816, 817, 818, 819, 820, 821, 822, 823, 824, 825, 826, 827, 828, 829, 830, 831, 832, 833, 834, 835, 836, 837, 838, 839, 840, 841, 842, 843, 844, 845, 84

Last Logon : 11 Oct 2009, 23:45:54

Password age :

Loans : 693

* Logons : 092

Si ce compte n'est pas vraiment administrateur du réseau, il faut lui retirer en urgence ce privilège.

3. L'existence d'un grand nombre de compte d'utilisateur sans mot de passe

[illegible]

Il faut absolument imposer aux utilisateurs de créer les mots de passe selon la politique qui a été fixée.

Détection des failles de sécurité

2- Seconde étape : Audit détaillée par ressource.

Liste des patches manquant



Missing Security Patches/Services

Windows Server 2003, Standard Edition Gold

MS04-041 - 885836

Vulnerability in WordPad Could Allow Code Execution (885836)

Registry key not found. (software\microsoft\windows nt\currentversion\hotfix\kb885836)

<http://www.microsoft.com/TechNet/security/bulletin/MS04-041.asp>

MS06-011 - 914798

Permissive Windows Services DACLS Could Lead to Elevation of Privilege (914798)

Registry key not found. (software\microsoft\updates\windows server 2003\sp1\kb914798)

<http://www.microsoft.com/TechNet/security/bulletin/MS06-011.asp>

Détection des failles de sécurité

2- Seconde étape : Audit détaillée par ressource.

Audit des services

CryptSvc - Services de cryptographie

dcevt32 - Systems Management Event Manager

DcomLaunch - Lanceur de processus serveur DCOM

dcstor32 - Systems Management Data Manager

Dfs - Système de fichiers distribués

Dhcp - Client DHCP

DHCPServer - Serveur DHCP

dmserver - Gestionnaire de disque logique

DNS - Serveur DNS

Dnscache - Client DNS

elementmgr - Gestionnaire d'élément Web

ERSvc - Service de rapport d'erreurs

Eventlog - Journal des événements

EventSystem - Système d'événements de COM+

helpsvc - Aide et support

HTTPFilter - HTTP SSL

IAS - Service d'authentification Internet

IISADMIN - Service d'administration IIS

Ismserv - Messagerie inter-sites

Détection des failles de sécurité

2- Seconde étape : Audit détaillée par ressource.

Exemple d'un récapitulatif de recommandation pour un tel serveur

- *Vérifier la nécessité des ports qui sont ouverts et fermer ceux qui ne le sont pas.*
- *Corriger les problèmes indiqués dans les rapports « Nessus »*
- *Désactiver et/ou arrêter les services inutiles sur le serveur*
- *Corriger les écarts indiqués dans le résultat du benchmark*
- *Retirer les comptes d'utilisateurs qui ne font plus partie du domaine*
- *Elaborer une politique pour les mots de passe qui soit plus restrictive*

Détection des failles de sécurité

2- Seconde étape : Audit détaillée par ressource.

Exemple d'un récapitulatif de recommandation pour un tel serveur

- *Priver les utilisateurs normaux des droits du super utilisateur*
- *Doter tous les utilisateurs de mots de passe pour leurs comptes d'accès au domaine.*

Détection des failles de sécurité

2- Seconde étape : Audit détaillée par ressource.

Exemple : Firewall

Détection des failles de sécurité

2- Seconde étape : Audit détaillée par ressource.

Exemple : Firewall

Description de la configuration des interfaces du Firewall

Nom de l'interface	Adresse IP	Masque	Observations
Interne	192.168.20.1 192.168.21.1	255.255.255.0 255.255.255.0	Même interface avec deux adresses IP
Wan 1 (LS)	196.203.117.34	255.255.255.248	Partagée entre les deux segments
Wan 2 (ADSL)	41.229.115.194	255.255.255.192	Hors exploitation
DMZ 1	192.168.0.1	255.255.255.0	Supervision
DMZ 2	Dynamique	255.255.255.0	-

Détection des failles de sécurité

2- Seconde étape : Audit détaillée par ressource.

Conformité par rapport à un référentiel :

Les rubriques suivantes ont été examinées lors de notre mission :

- ❑ Analyse de la configuration de l'équipement
- ❑ Conformité par rapport à un benchmark (voir annexe) :
- ❑ Le système de management du Firewall,
 - L'authentification,
 - L'application des vérifications standards pour le contrôle d'accès,
 - La désactivation des services de gestion non utilisés,

Détection des failles de sécurité

2- Seconde étape : Audit détaillée par ressource.

Conformité par rapport à un référentiel :

- Le système de contrôle,
 - La synchronisation du Firewall via un serveur NTP,
 - L'application des règles standards d'authentification,
 - La désactivation des services de contrôle non utilisés
 - La désactivation des services de routage non utilisés
- La vérification des règles et des données relatives au flux de données
 - L'activation des protocoles HTTP, FTP et SMTP,
 - La définition du temps d'inactivité

Détection des failles de sécurité

2- Seconde étape : Audit détaillée par ressource.

Exemple : Audit détaillé de postes de travail

Détection des failles de sécurité

Liste des services inutiles sur les stations Microsoft

Nom du service	Démarrage par défaut	Démarrage conseillé	Remarques
Accès à distance au Registre	Automatique	Désactivé	Pour des raisons de sécurité, ce service est à désactiver.
Administration IIS	Automatique	Désactivé	Service utile que s'il y a eu création avec IIS d'un serveur Web, FTP ou SMTP
Aide et support	Automatique	Manuel	Si l'utilisateur ne se sert pas beaucoup de cette rubrique d'aide il est inutile de mettre ce service au démarrage automatique
Carte à puce	Manuel	Désactivé	L'authentification sur l'ordinateur ne se fait pas par carte à puce, ce service est donc inutile.
Carte de performance WMI	Manuel	Désactivé	Ce service est à désactiver.
Configuration automatique sans fil	Automatique	Désactivé	Aucun périphérique réseau sans fil n'est installé, ce service est inutile.
Fax	Manuel	Désactivé	Ce service n'est nécessaire qu'en cas de l'utilisation du fax
Gestionnaire de téléchargement	Automatique	Désactivé	Service utilisé pour envoyer des informations sur vos pilotes à Microsoft pour vérifier la disponibilité des informations.
Publication FTP	Automatique	Désactivé	A démarrer automatiquement

Détection des failles de sécurité

2- Seconde étape : Audit détaillée par ressource.

Audit de la protection antivirale des serveurs et des postes de travail

Troisième phase

Test Intrusif



Tests d'intrusion

- ❑ Les tests d'intrusion consistent à éprouver les moyens de protection d'un système d'information en essayant de s'introduire dans le système en situation réelle.
- ❑ Un test d'intrusion ne peut pas constituer une assurance que le système d'information est tout à fait sécurisé, ni aboutir à la délivrance d'une liste exhaustive des vulnérabilités du système d'information

Tests d'intrusion

On distingue généralement deux méthodes distinctes :

- La méthode dite « boîte noire » (en anglais « *black box* ») consistant à essayer d'infiltrer le réseau sans aucune connaissance du système, afin de réaliser un test en situation réelle ;
- La méthode dite « boîte blanche » (en anglais « *white box* ») consistant à tenter de s'introduire dans le système en ayant connaissance de l'ensemble du système, afin d'éprouver au maximum la sécurité du réseau

Tests d'intrusion

Une telle démarche doit nécessairement être réalisé avec **l'accord (par écrit de préférence) du plus haut niveau de la hiérarchie de l'entreprise.**

On recourir à d'autres outils tels que : Socat, Hping, Fping, Nmap, Arp, ainsi qu'à des scripts développés en interne au cas par cas.

Pour les environnements Windows, Pwdump est exploité pour l'extraction de mots de passe cryptés, comme Fgdump (Metasploit ou milw0rm pour Linux/Unix).



Tests d'intrusion

Sur le volet des applications Web : Paros Proxy, Burp Suite et WebScarab.

Ces derniers sont des outils proxy qui vont émuler le navigateur pour tester des actions sur des services Web.

Des extensions de sécurité s'intégrant directement à Firefox permettent également de réaliser des tests d'intrusion.

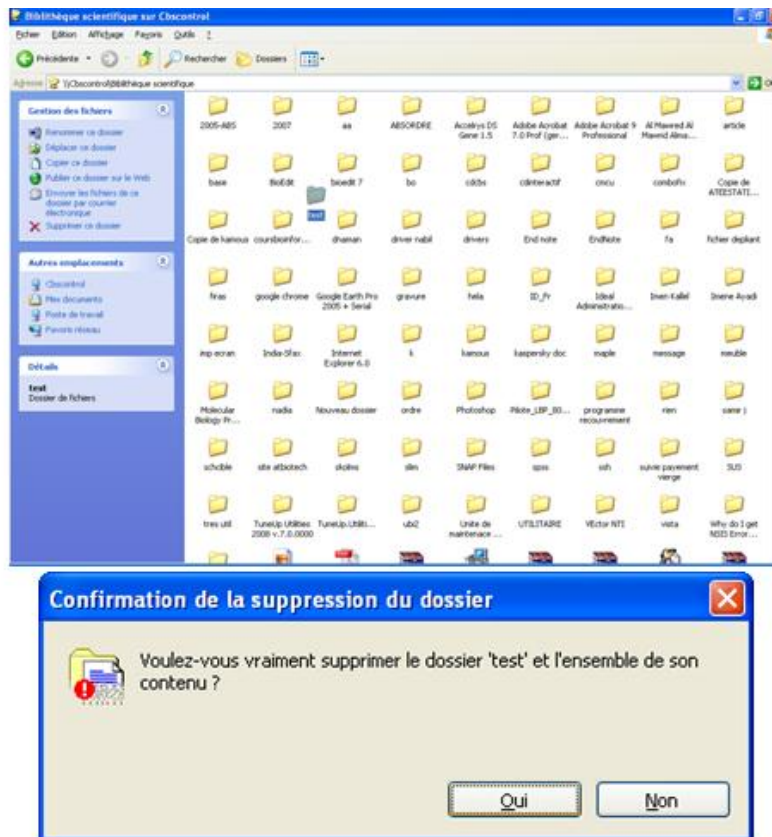
Autres outils

<https://free-security.org/ouils-securite-informatique.php>

Tests d'intrusion

- ***Exemples de test a effectuer***
- ***Accès FTP anonyme***
- ***Intrusions sur les ressources partagées du réseau***
- ***....***

Tests d'intrusion



Exemple test intrusif sur une plateforme web

- ❑ Pour exploiter cette faille, il suffit d'appeler l'url du site cible:
- ❑ `index.php?option=com_user&view=reset&layout=confirm`

Confirmez votre demande

Un e-mail a été envoyé dans votre boîte de messagerie. L'e-mail contient un **code de vérification**. Veuillez copier-coller le code en question dans le champ ci-dessous à titre de vérification

:Code de vérification

Envoyer

... dans le champ du formulaire, Joomla vous propose de saisir un nouveau mot de passe administrateur par exemple « sahbi » :

Exemple test intrusif sur une plateforme web



Réinitialiser votre mot de passe

.Pour terminer la ré-initialisation de votre mot de passe, veuillez saisir un **nouveau mot de passe**

:Mot de passe

:Vérification du mot de passe

Envoyer

En fin aller à l'url :

/administrator/

saisir comme login « admin » et mot de passe « sahbi », en effet nous aurons un accès total sur la partie administration du site :

Site
Menus
Contenu
Composants
Extensions
Outils
Aide

compatibilité: 1.0
Prévisualiser
0
1
Déconnexion


Ajouter un nouvel article


Gestion des articles


Gestion de la page d'accueil


Gestion des sections


Gestion des catégories


Gestion des médias


Gestion des menus


Gestion des langues


Gestion des utilisateurs


Configuration

▼ Logged in Users

#	Nom	Groupe	Client	Dernière activité	Déconnexion
1	admin	Super Administrator	administrator	0.0 heures	

▶ Popular

▶ Recent added Articles

▶ Menu Stats

Pour comprendre la faille de sécurité, il faut se rendre dans le fichier `/components/com_user/models/reset.php` à la ligne contenant ce code : `SELECT id FROM #__users WHERE block = 0 AND activation = '.$db->Quote($token)`

Lorsque l'on fait une demande de réinitialisation de mot de passe et que l'on fournit notre jeton spécial (apostrophe), la requête SQL suivante est alors exécutée :